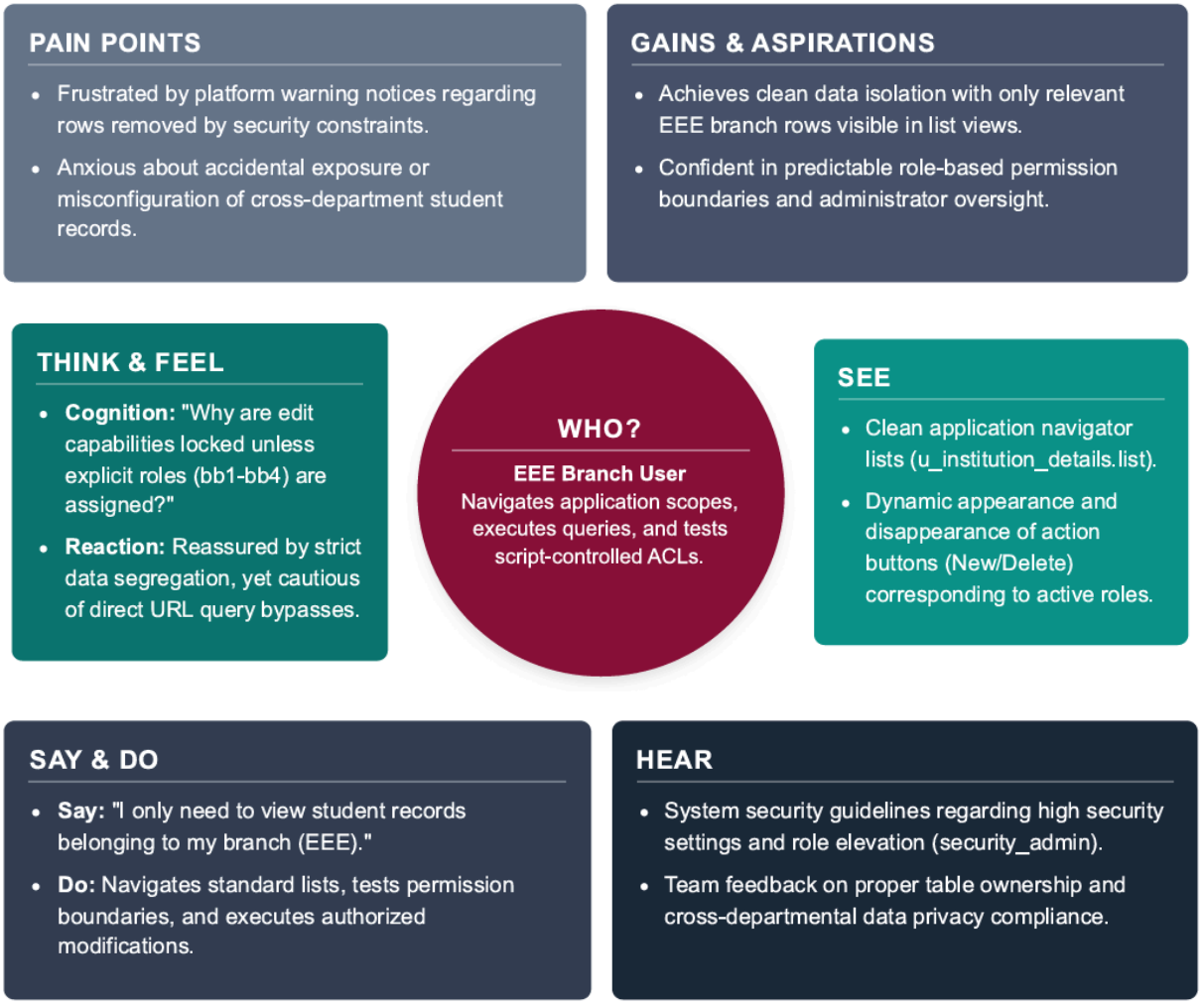
Ideation Phase

Empathize & Discover

Date	28-10-2026
Team ID	SWTID-2026-7875
Project Name	Script-Controlled ACL – Restrict Record Access Based on Field Value

1. VISUAL EMPATHY MAP CANVAS



2. STAKEHOLDER DISCOVERY & EMPATHY INSIGHTS

PERSONA CLASS	OBSERVED BEHAVIORAL FRICTION	CORE OPERATIONAL EXPECTATION
Department User *(e.g., EEE User)*	Sees irrelevant records or receives security constraint banners when querying global table views.	Wants clean, automated filtering that shows only EEE records without extra administrative hurdles.
Security Admin *(System Administrator)*	Risk of unauthorized data exposure if access relies solely on UI policies or static role toggles.	Enforces database-level CRUD validation (`Read`, `Create`, `Write`, `Delete`) via server-side ACL scripts.

3. DETAILED PERSONA PROFILES

PROFILE DIMENSION	DEPARTMENT USER (EEE BRANCH)	SECURITY ADMINISTRATOR (`SECURITY_ADMIN`)
Primary Goal	Access and manage student records assigned strictly to the EEE branch efficiently.	Protect platform data integrity and enforce strict multi-tenant branch segregation.
Assigned Roles	Custom operational roles (`bb1` Read, `bb2` Create, `bb3` Write, `bb4` Delete).	Elevated `security_admin` and platform `admin` roles.
Pain Points	Visual clutter from other branches; unexpected read-only or denied operation states.	Potential security loopholes if users bypass UI controls using direct table API calls.
Success Metric	Zero non-EEE records visible in list views; seamless CRUD execution for authorised rows.	100% database-enforced record security with active administrative overrides intact.

4. PROBLEM STATEMENT & IDEATION MAPPING

EMPATHY PAIN POINT	CORE PROBLEM STATEMENT	PROPOSED ACL SOLUTION
Cross-Branch Exposure	Users can view records belonging to other academic departments.	Implement a scripted `Read` ACL checking `Branch == EEE` alongside user role `bb1`.
Over-Privileged Actions	Granting record viewing rights inadvertently allows editing or deletion.	Decouple operation rights into dedicated `Create` (`bb2`), `Write` (`bb3`), and `Delete` (`bb4`) ACLs.
List Security Constraint Messages	Standard ACLs hide rows but display annoying system warning messages on list views.	Pair `Read` ACLs with a `Before Query` Business Rule to pre-filter list datasets seamlessly.

5. ACTIONABLE IMPLEMENTATION ROADMAP

Phase 1:

Dynamic Role Checking Refactor `bb1`–`bb4` static script checks to dynamically query user branch profiles via `sys_user` lookups.

Phase 2:

Business Rule Synergy Deploy `Before Query` Business Rules on `u_institution_details` to filter lists prior to ACL evaluation